Web Application Security Manual Audit Report

For

DILRMP

Audit Scope : http://10.1.43.55
Reference ID : IHAT-06022026-0001
Level : Initial 1
Date : 26-February-2026

Contact Us:
Application Security Division, National Informatics Centre, A-Block, CGO Complex, Lodhi Road, New Delhi – 110003

webappsec@nic.in 011-24305872

Confidential Report,
Not to be circulated or reproduced without appropriate authorization

Document History:

S.No.	Date	Level	Purpose	Author	Reviewed by
1.	26/02/2026	1	Initial	Nandini Sharma	Ashish Sharma

Contributions:

S.No.	Name	Role	Organization
1.	Nandini Sharma	Auditor	AKS IT Services Pvt. Ltd.
2.	Ashish Sharma	Reviewer	AKS IT Services Pvt. Ltd.
3.	Sunita Maurya	Coordinator & Point of Contact	NIC
4.	Mr. Anil Kumar Jha	HOD	NIC
5.	Mr. Rajesh Mishra	HOG	NIC

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

TABLE OF CONTENTS

TABLE OF CONTENTS 3
Executive Summary 4
OWASP Top 10 & other Vulnerabilities for the website 5
Detailed Findings 6
1. Vulnerability: Privilege Escalation (Open) 6
How test was performed 6
Solution 8
2. Vulnerability: Host Header Attack (Open) 9
How test was performed 9
Solution 10
3. Vulnerability: Improper Error Handling (Open) 11
How test was performed 11
Solution 12
4. Vulnerability: Sensitive Information Disclosure (Open) 13
How test was performed 13
Solution 14
5. Vulnerability: Autocomplete Enabled (Open) 15
How test was performed 15
Solution 16
6. Vulnerability: Improper Implementation of CAPTCHA (Open) 17
How test was performed 17
Solution 17
7. Vulnerability: Security Logging and Monitoring Failure (Open) 18
How test was performed 18
Solution 18
8. Vulnerability: Lack of Security Header (Open) 19
How test was performed 19
Solution 20
9. Vulnerability: Missing Cookie Attributes (Open) 21
How test was performed 21
Solution 21
10. Vulnerability: Username Enumeration (Open) 22
How test was performed 22
Solution 23
Observation 24
Tools Used 29

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Executive Summary

This report documents the findings of the Web Application security audit report for the application **DILRMP.** The objective of the audit was to find out vulnerabilities that can be seen and compromised by malicious users. The sections below describe the business risk involved and the corresponding technical vulnerabilities.

Summary of Findings

Findings and Vulnerabilities description is tabulated below:

Finding No.	Vulnerability Description	Severity	Status
1.	Privilege Escalation	High	Open
2.	Host Header Attack	Medium	Open
3.	Improper Error Handling	Low	Open
4.	Sensitive Information Disclosure	Low	Open
5.	Autocomplete Enabled	Low	Open
6.	Improper Implementation of CAPTCHA	Low	Open
7.	Security Logging and Monitoring Failure	Low	Open
8.	Lack of security header	Low	Open
9.	Missing Cookie Attributes	Low	Open
10.	Username Enumeration	Low	Open

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

OWASP Top 10 & other Vulnerabilities for the website

S.No.	OWASP Top 10 Vulnerabilities	Status (Safe/ Unsafe/NA)
1	A01:2021-Broken Access Control	Unsafe
2	A02:2021-Cryptographic Failures	Safe
3	A03:2021-Injection	Safe
4	A04:2021-Insecure Design	Safe
5	A05:2021-Security Misconfiguration	Unsafe
6	A06:2021-Vulnerable and Outdated Components	Safe
7	A07:2021-Identification and Authentication Failures	Unsafe
8	A08:2021-Software and Data Integrity Failures	Safe
9	A09:2021-Security Logging and Monitoring Failures	Unsafe
10	A10:2021-Server-Side Request Forgery	Safe

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Detailed Findings

1. Vulnerability: Privilege Escalation (Open)

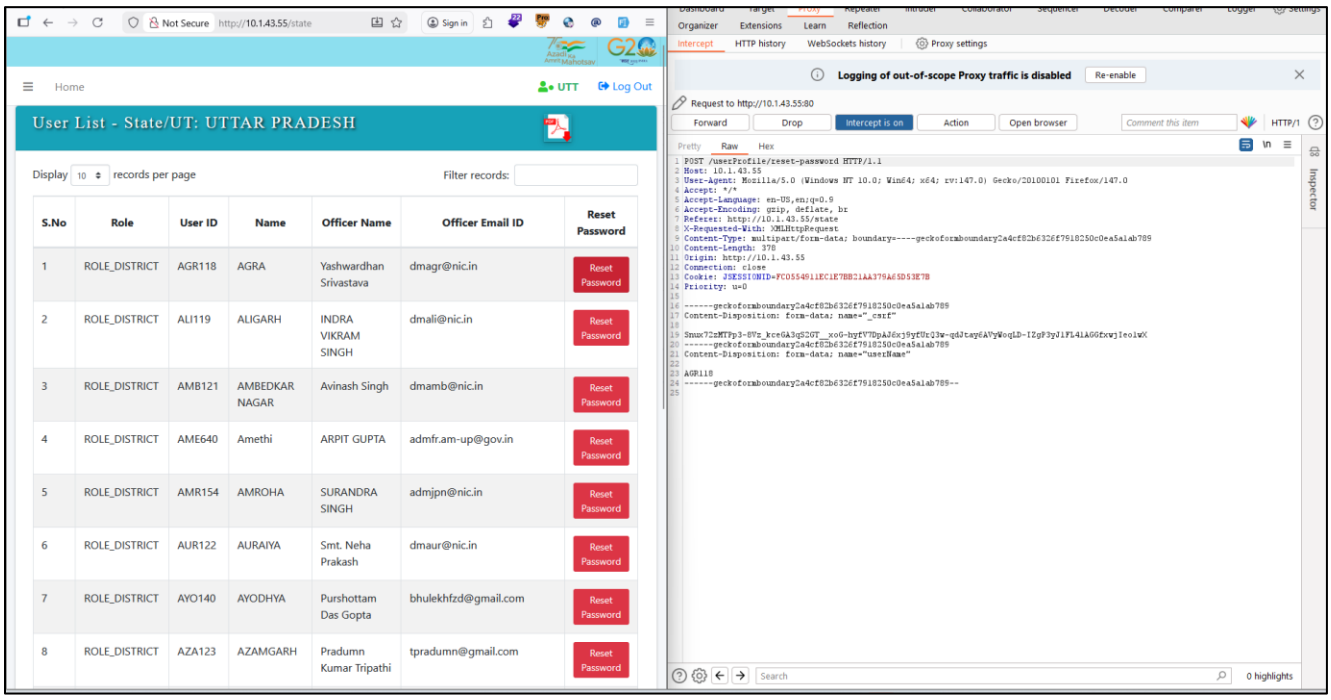
Description: Frequently, an application only protects sensitive functionality by preventing the display of links or URLs to unauthorized users. Attackers can use this weakness to access and perform unauthorized operations by accessing those URLs directly.

Risk Rating	Probability of Attack	Complexity of Attack
High	**High**	**High**

Impact: Such flaws allow attackers to access unauthorized functionality. Administrative functions are key targets for this type of attack.

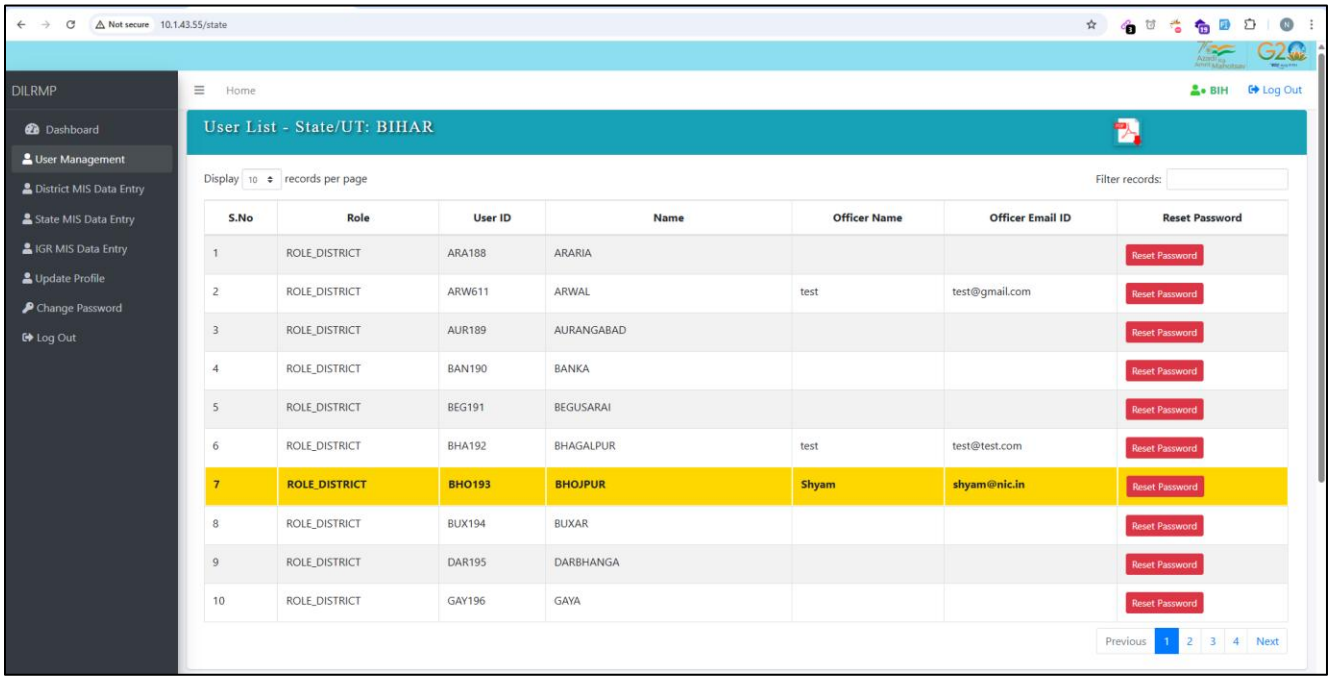
How test was performed

Step I: Login to the application as UTT and intercept the reset password request as shown in the snapshot below:

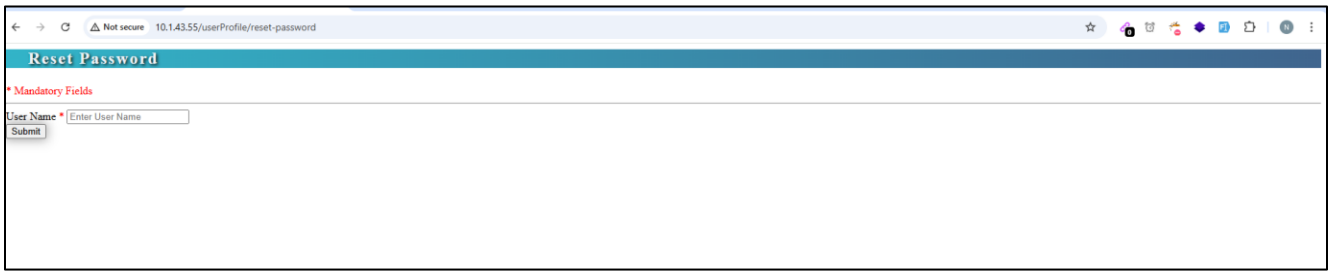


This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

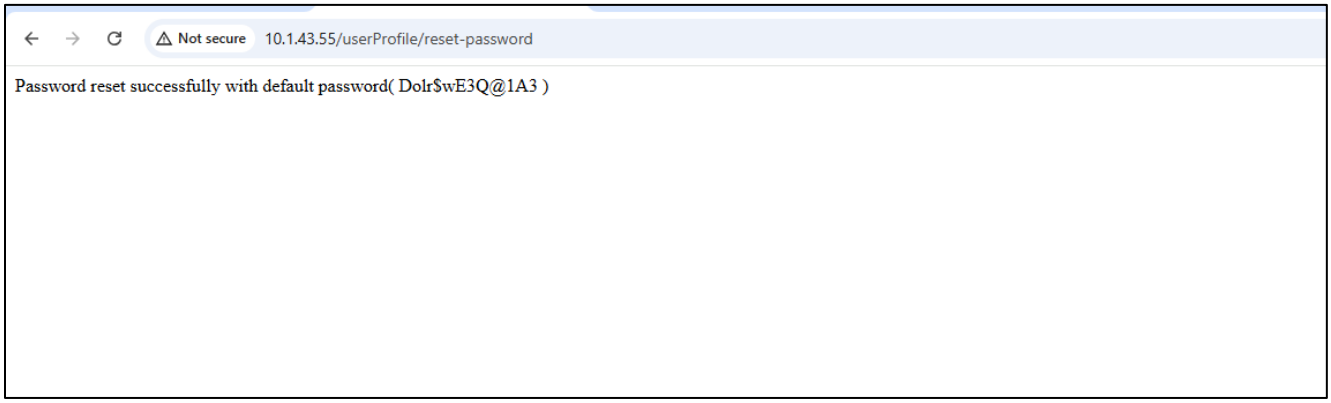
Step II: Now login with BIH user in different browser as shown in the snapshot below:



Step III: Now copy the above intercepted reset password request URL from UTT user role and paste it in BIH user role and enter any user name and observe that password is reset as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.



Solution

Create an access control matrix and map each role of the application as per the transactions allowed for each role.
The authentication and authorization policies be role based, to minimize the effort required to maintain these policies.
The policies should be highly configurable, in order to minimize any hard coded aspects of the policy.
The enforcement mechanism(s) should deny all access by default, requiring explicit grants to specific users and roles for access to every page.
If the page is involved in a workflow, check to make sure the conditions are in the proper state to allow access.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

2. Vulnerability: Host Header Attack (Open)

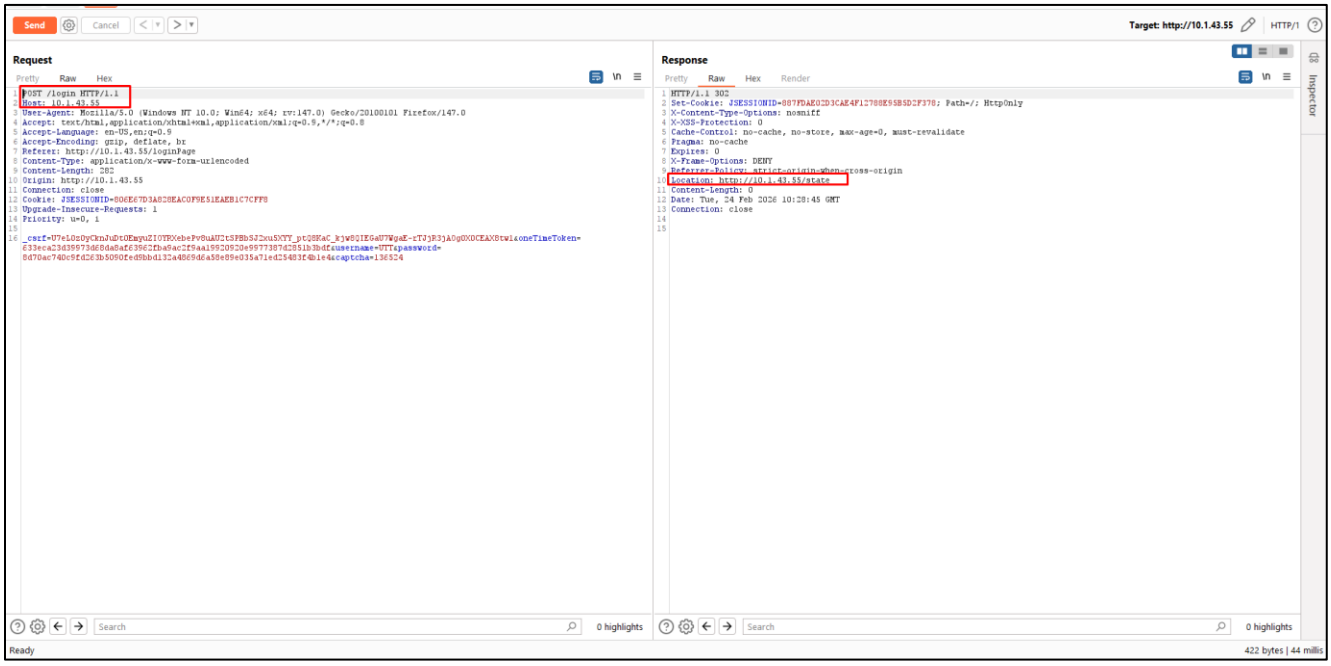
Description: Many web applications rely on the HTTP host header to understand "where they are". Unfortunately, what many application developers do not realize is that the HTTP host header is controlled by the user. In application security user input should always be considered unsafe and therefore, never trusted without properly validating it first.

Risk Rating	Probability of Attack	Complexity of Attack
Medium	**Medium**	**Medium**

Impact: The two major attack vectors host header attacks enable are web-cache poisoning, and abuses of alternative channels for conducting sensitive operations, such as password resets.

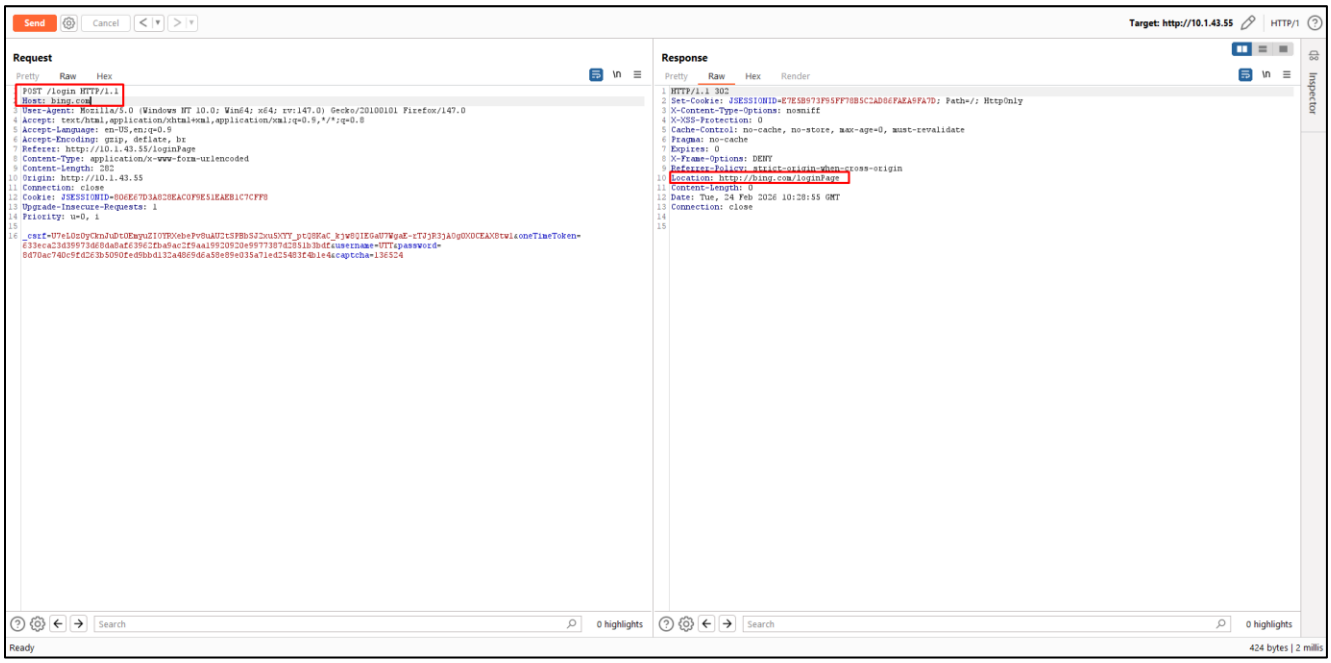
How test was performed

Step I: Intercept the URL "http://10.1.43.55/login" and observe that host header in the request as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Step II: Now change the value of host header to "bing.com" and observe that it is reflected in Location header in response as shown in the snapshot below:



Solution

Validating Host header to ensure that the request is originating from that target host or not. By creating a white list of trusted domains during the initial setup of the application and mapping domains received in Host header of each and every request with it.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

3. Vulnerability: Improper Error Handling (Open)

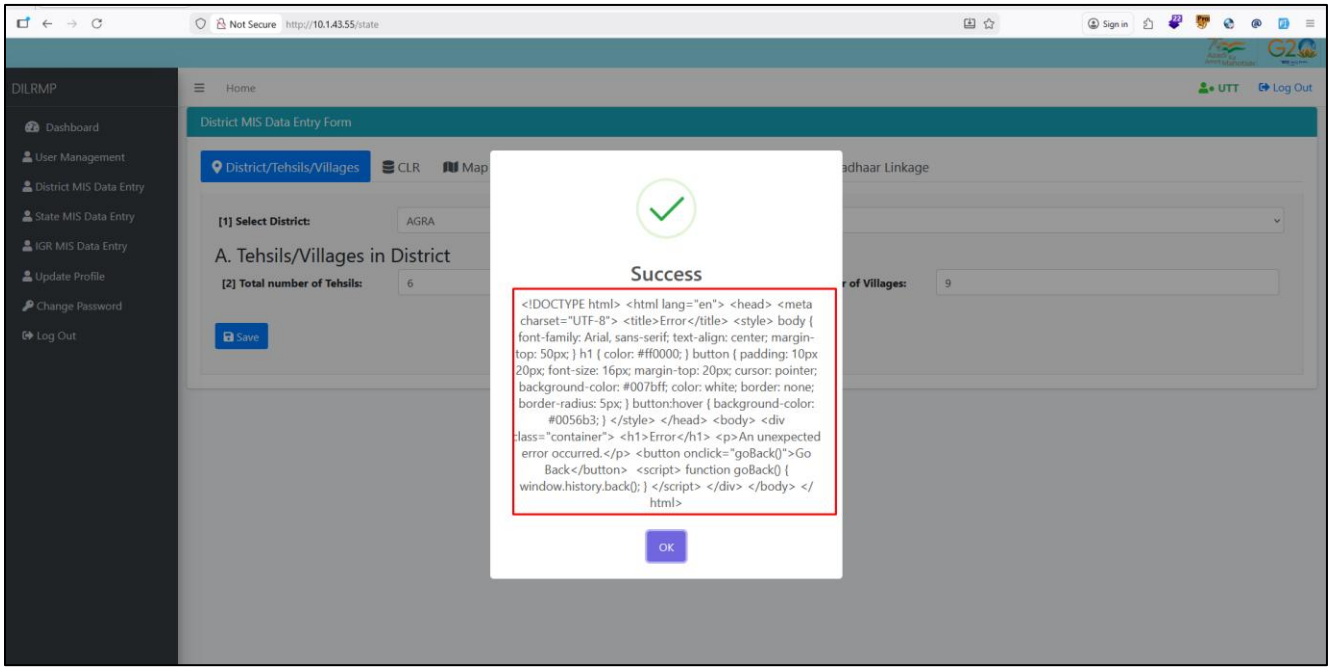
Description: Applications can unintentionally leak information about their configuration, internal workings, or violate privacy through a variety of application problems. Attackers use this weakness to steal sensitive data or conduct more serious attacks.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: Depends on the information, such flaws frequently give attackers unauthorized access to some system data or functionality. Occasionally, such flaws result in a complete system compromise.

How test was performed

Step I: Login to the application as UTT, go to "http://10.1.43.55/state" and click on save and observe that application is disclosing html code as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Solution

Ensure that a customized error message is shown for any error that has occurred, which gives out very limited information.
Disable or limit detailed error handling. In particular, do not display debug information to end users, stack traces, or path information.
Application should make secure to prevent revealing of any kind of error and Hardening process should be carried out periodically.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

4. Vulnerability: Sensitive Information Disclosure (Open)

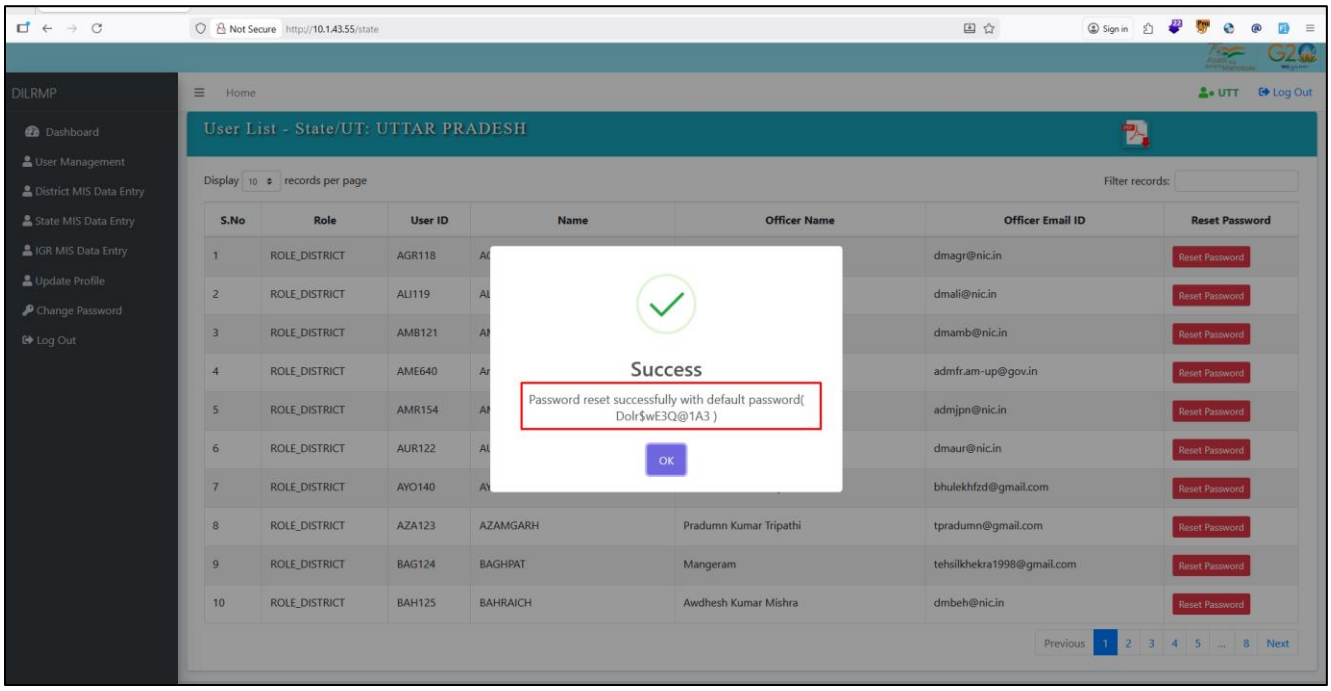
Description: The application discloses sensitive information by displaying the default/reset password on the screen after a password reset. Passwords are confidential authentication credentials and should never be exposed in clear text in the user interface, API responses, or logs. Displaying the password results in an information disclosure vulnerability.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: An attacker or unauthorized person viewing the screen (e.g., through shoulder surfing, shared systems, screen recording, or remote access) can capture the password and gain unauthorized access to the account. If the affected account has elevated privileges, this may lead to account takeover and potential system compromise.

How test was performed

Step I: Login to the application and click on password reset and observe that password is popped up in screen as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Solution

The application should not display passwords after reset. Instead, implement a secure password reset mechanism using a one-time reset link or token sent to the registered email address. Enforce password change on first login and ensure passwords are securely hashed and never returned in responses.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

5. Vulnerability: Autocomplete Enabled (Open)

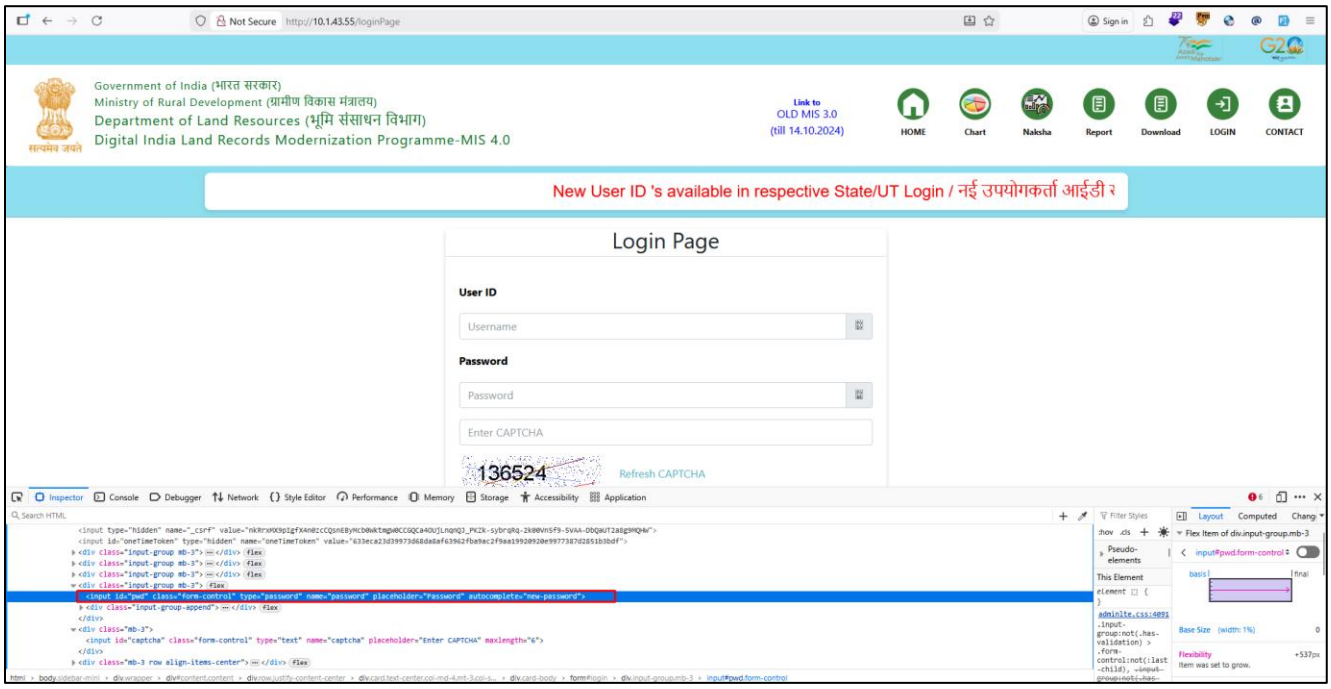
Description: Most browsers have a facility to remember user credentials that are entered into HTML forms. This function can be configured by the user and also by applications that employ user credentials. If the function is enabled, then credentials entered by the user are stored on their local computer and retrieved by the browser on future visits to the same application.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: The stored credentials can be captured by an attacker who gains control over the user's computer. Further, an attacker who finds a separate application vulnerability such as cross-site scripting may be able to exploit this to retrieve a user's browser-stored credentials.

How test was performed

Step I: Go to "http://10.1.43.55" and inspect the password field and it was found that autocomplete value at password field is not set to off as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Solution

To prevent browsers from storing credentials entered into HTML forms, include the attribute autocomplete="off" within the FORM tag (to protect all form fields) or within the relevant INPUT tags (to protect specific individual fields).

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

6. Vulnerability: Improper Implementation of CAPTCHA (Open)

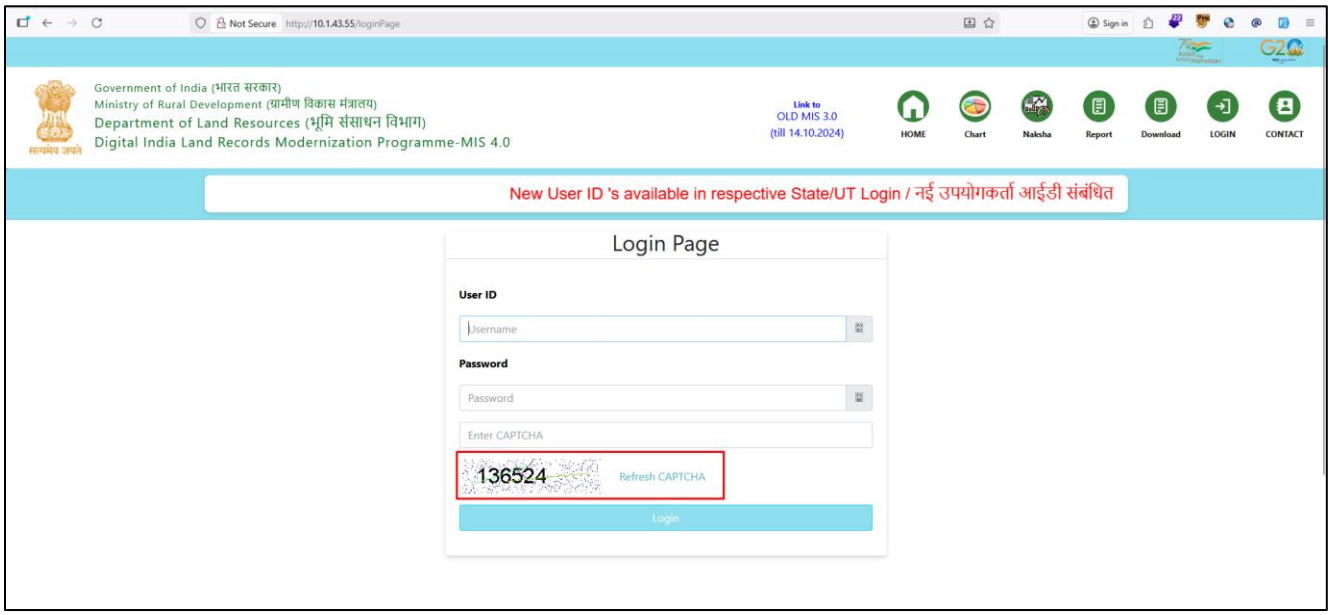
Description: CAPTCHA can be bypassed or is ineffective against automated requests, allowing bots to pass as legitimate users.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: Enables brute-force attacks, automated abuse, credential stuffing, and account compromise.

How test was performed

Step I: It was observed that static CAPTCHA is used as shown in snapshot below:



Solution

Implement 6-digit dynamic alpha-numeric image-based CAPTCHA validating on server side.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

7. Vulnerability: Security Logging and Monitoring Failure (Open)

Description: The application does not maintain any record of the application usage in the form of a report or audit trail. Any malicious activity cannot be monitored or traced back. In case of any misuse or attack, it may be difficult to trace and locate the origin.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: Insufficient logging and monitoring allow attackers to further attack systems, maintain persistence, pivot to more systems, and tamper, extract, or destroy data.

How test was performed

Step I: It has been observed that there are no logs maintained at the admin.

Solution

Information to be logged includes the following: IP address of the originating Source, Date, Time, Username (No Password), session details, Referrer, Process id, URL, User Agent, Countries if any in addition to other details to be logged in the website.
Logging of Authentication Process which includes number of successful and failed login attempts.
To create audit logs, use auto numbering so that every logged entry has an un-editable log number. Then if one audit entry is deleted a gap in the numbering sequence will appear.
Report of the website logs to be generated weekly by the administrator to keep track of the website activities.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

8. Vulnerability: Lack of Security Header (Open)

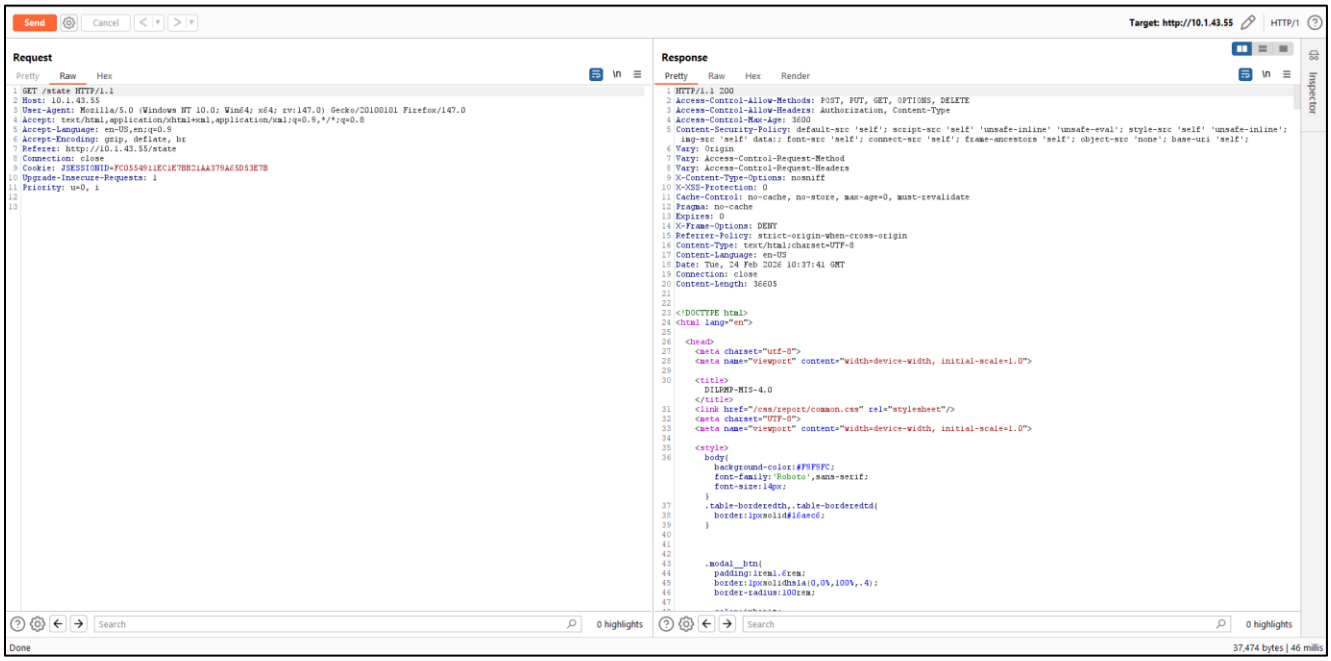
Description: The application has improperly implemented security response headers.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: The application has improperly implemented security headers, as an attacker may take advantage of this vulnerability and may perform attacks like clickjacking and Cross Site Scripting.

How test was performed

Step I: Go to "http://10.1.43.55/state" and intercept the request using Burp Suite and send the intercepted request to Burp Repeater and observe that permission policy is not implemented and CSP is not implemented properly as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Solution

- Implement Permission policy in security response headers.
- Remove unsafe-inline and unsafe-eval from CSP response headers.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

9. Vulnerability: Missing Cookie Attributes (Open)

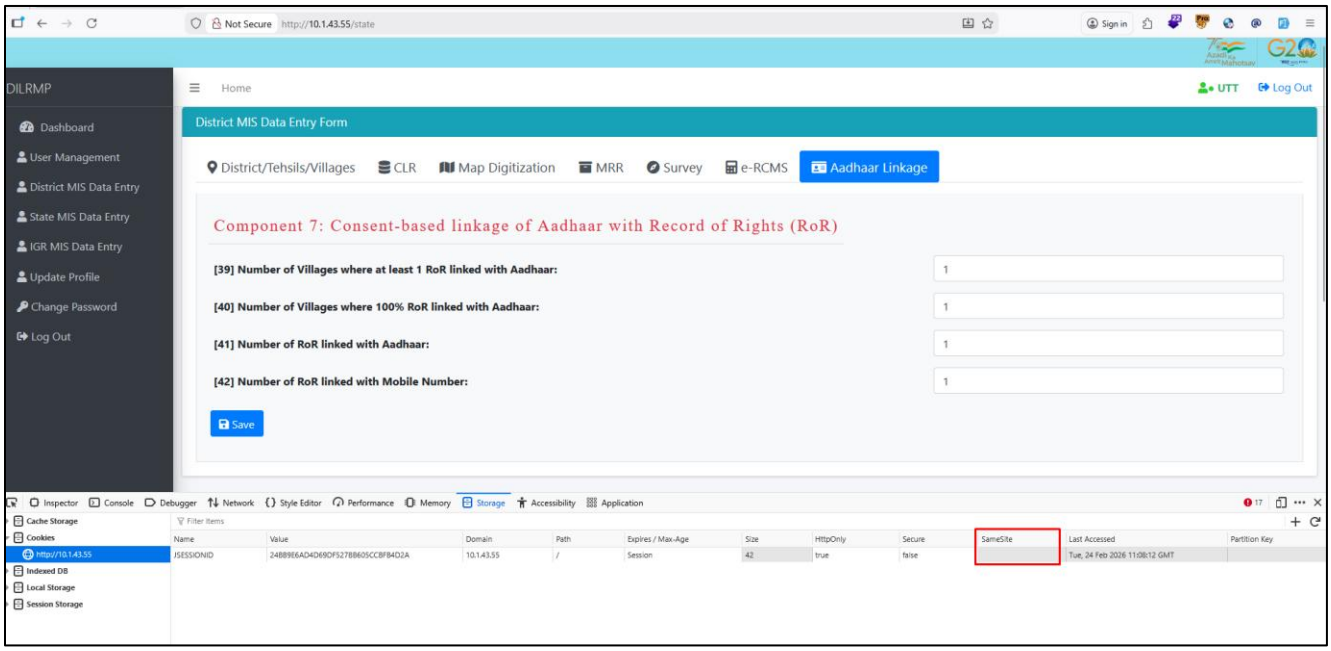
Description: Cookie do not have the proper attributes set. When the server responds with Set-Cookie header, it should assign the attributes of the cookies.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: The cookies can be accessed by an attacker and cause further attacks based on the level of exploitation.

How test was performed

Step I: Login to the application and inspect the page and observe that SameSite cookie attribute is not set as shown in the snapshot below:



Solution

The SameSite should be set to Lax/Strict as required by the application.

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

10. Vulnerability: Username Enumeration (Open)

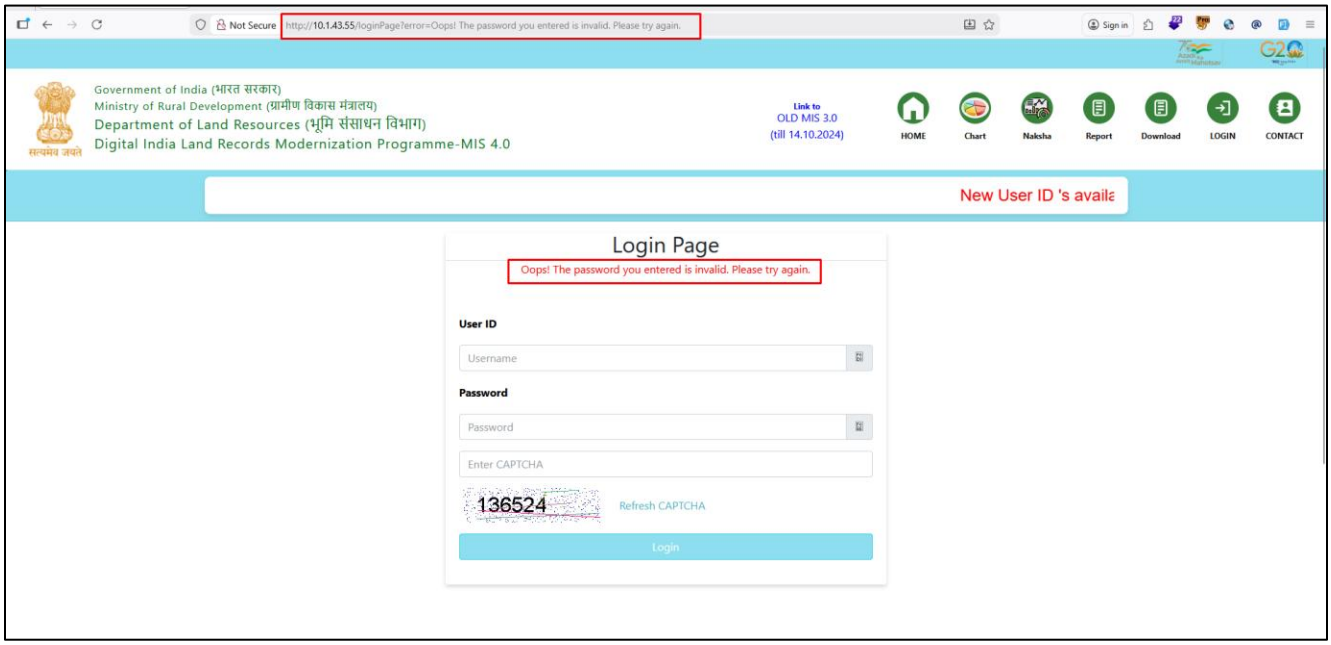
Description: One of the most common and underestimated web application vulnerabilities that is user enumeration. Simply put, we can figure out a list of valid user accounts that are allowed to login to an application. This isn't just assuming there's a common user called "Admin" and attempting to guess the password for that account. Instead, this is the ability to compile a list of valid users based on a flaw in the registration process, login sequence, or password reset functionality.

Risk Rating	Probability of Attack	Complexity of Attack
Low	**Low**	**Low**

Impact: Although username enumeration is not itself always a high-risk issue, it does provide an attacker valuable information for other attacks.

How test was performed

Step I: Go to "http://10.1.43.55/" and enter incorrect password and observe that Invalid password message is occurred as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Solution

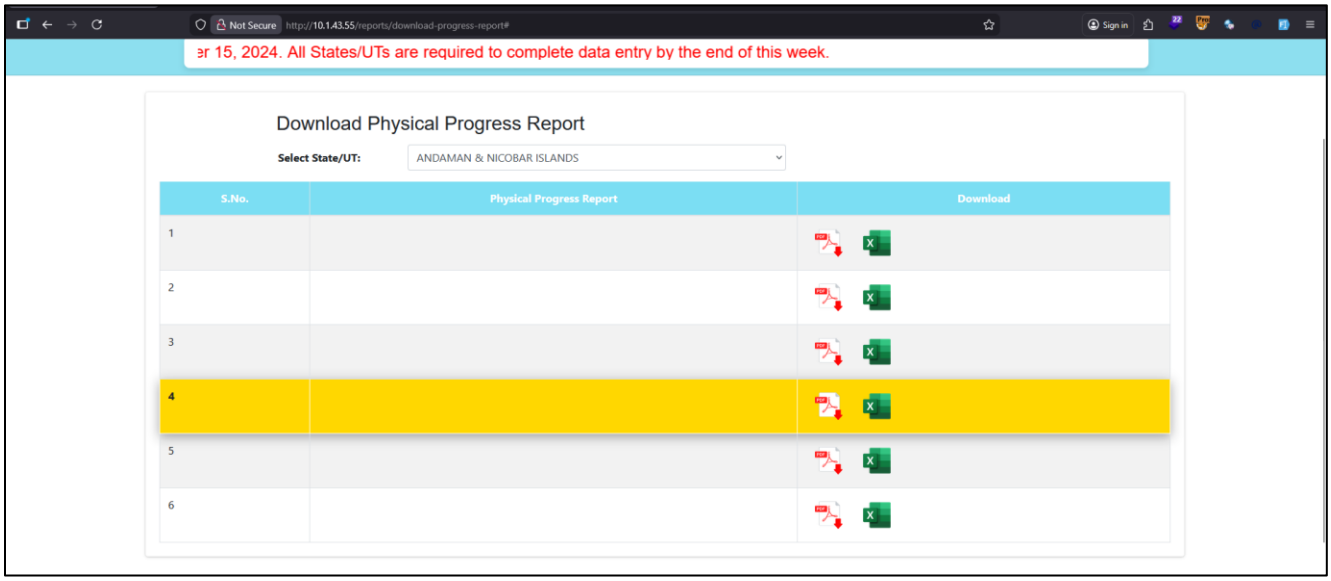
Make sure to return a generic "No such username or password" message when a login failure occurs. Make sure the HTTP response, and the time taken to respond are no different when a username does not exist, and an incorrect password is entered.

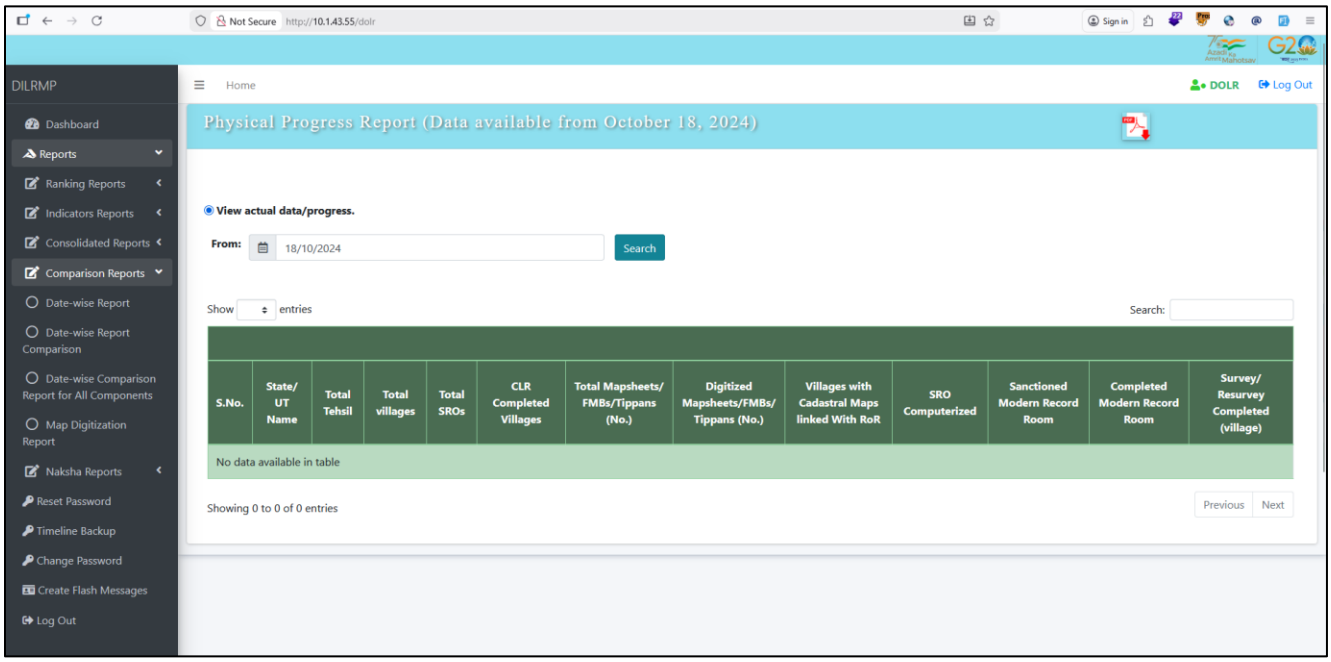
This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Observation

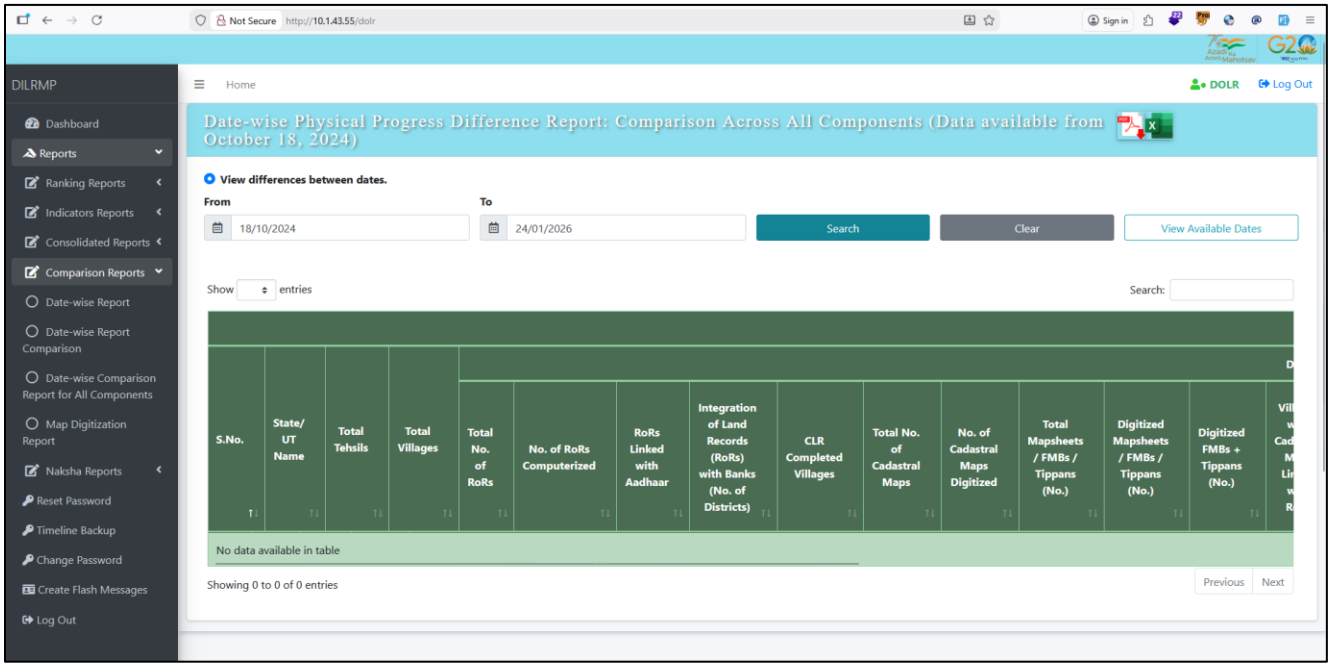
Case-I: Not data found

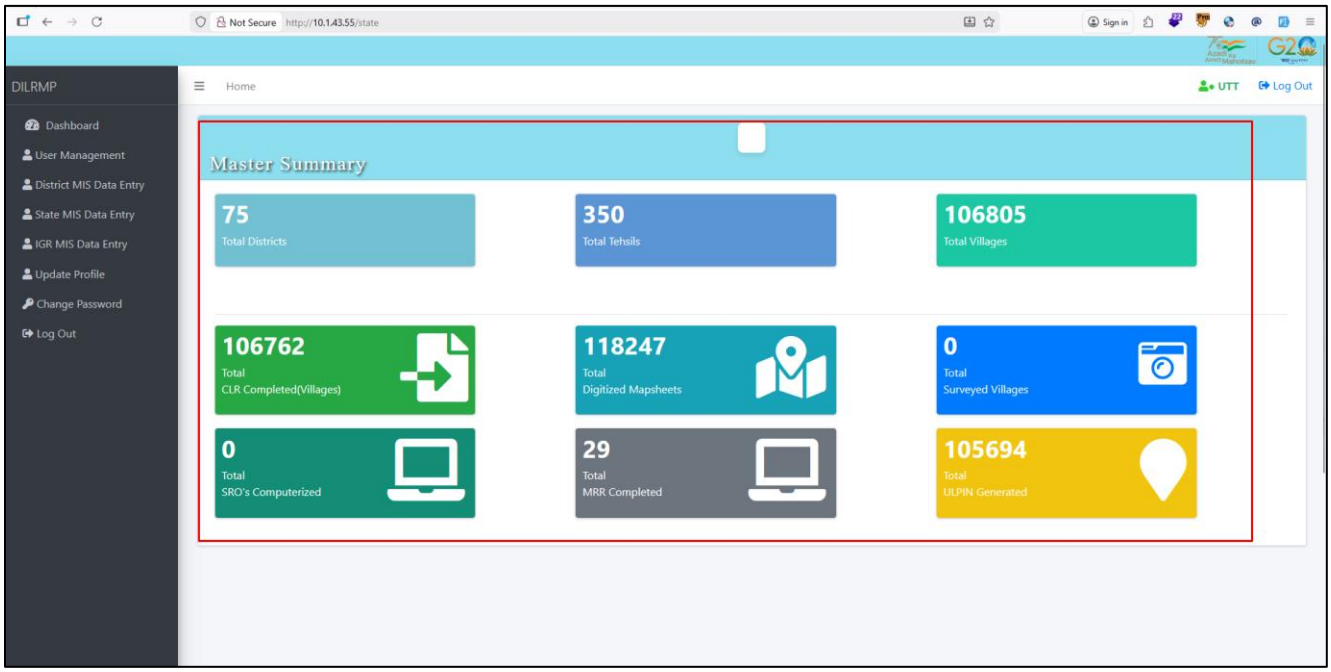
Step I: It was observed that data is not found on the following functionalities as shown in the snapshot below:





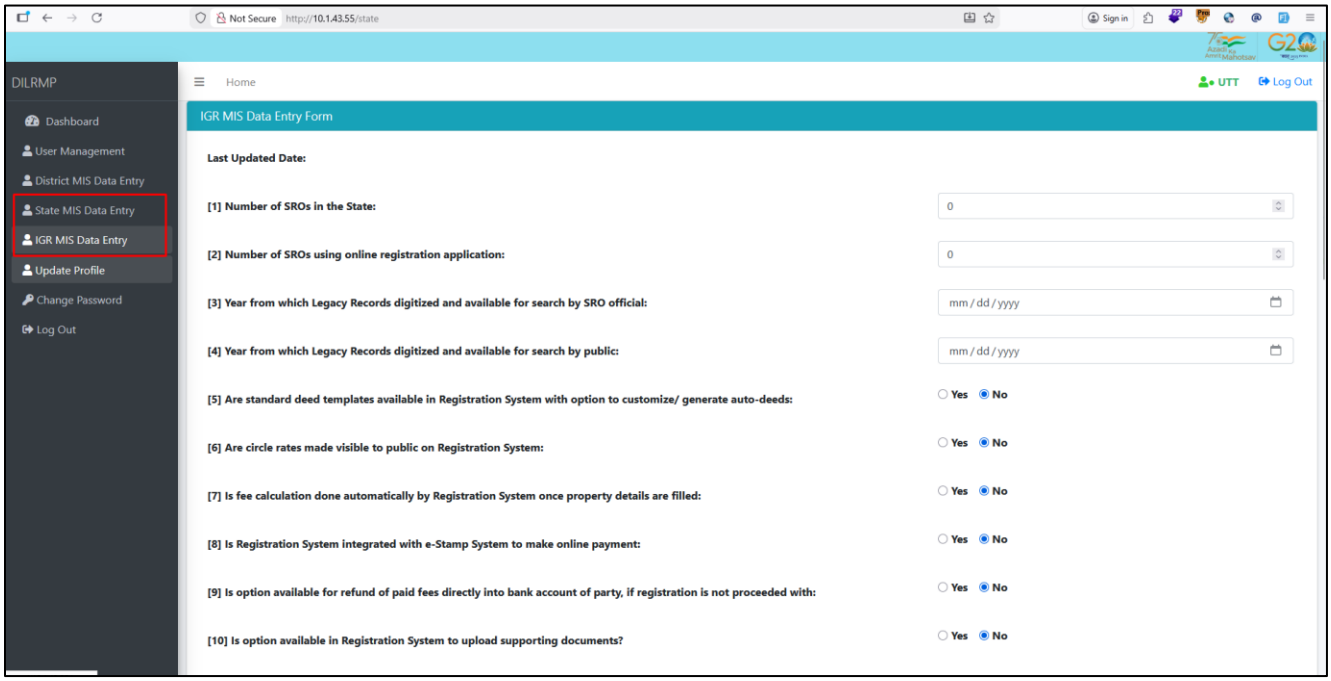
This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.





This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

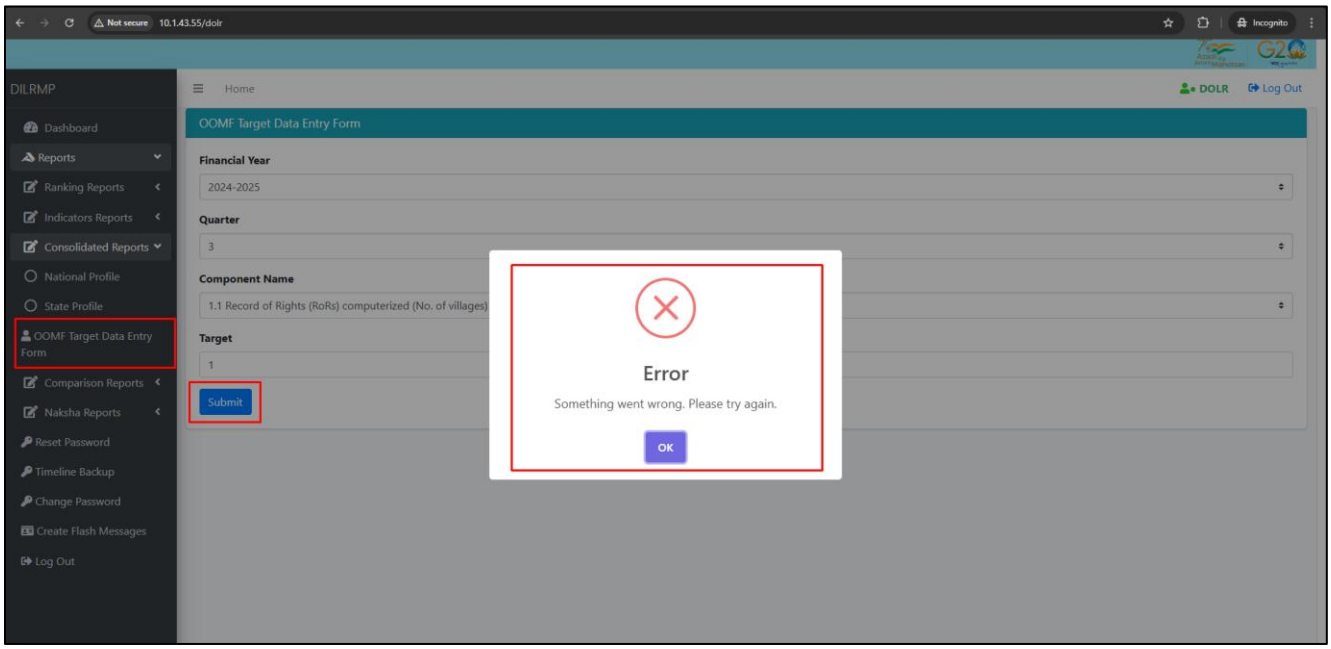
Step II: We are not able to find where data is saved as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Case-II: Error Encountered

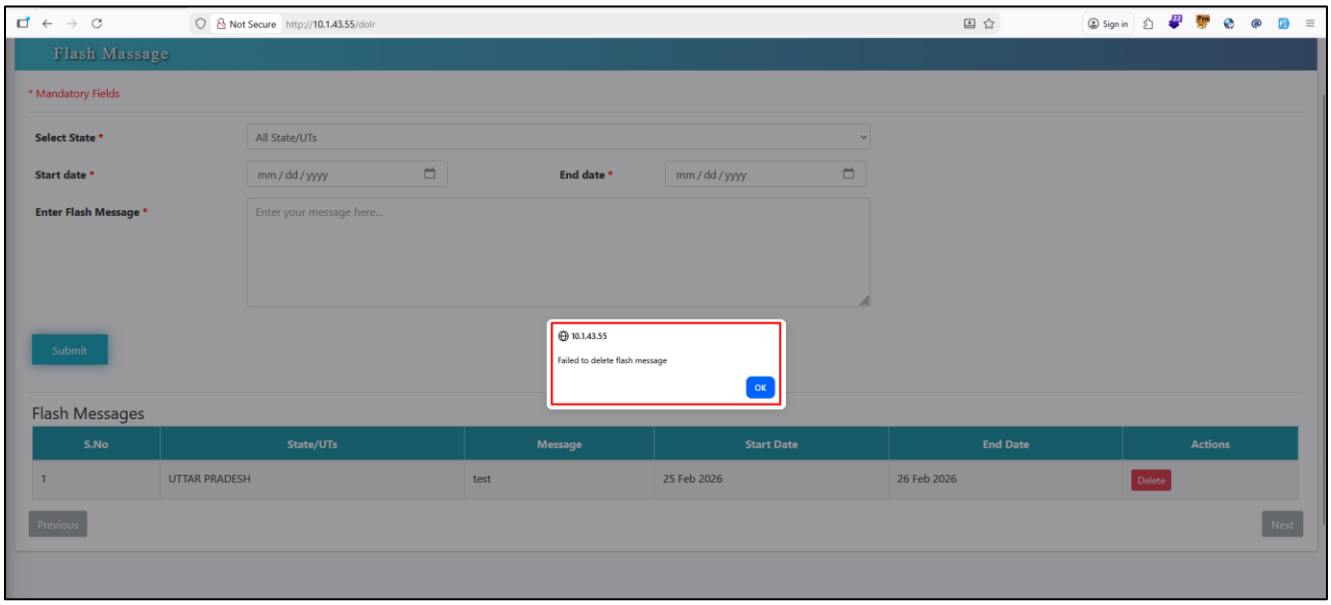
Step I: It was observed that while clicking on submit error is encountered as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Case-III: Functionality not working

Step I: It was observed that we are not able to delete flash messages as shown in the snapshot below:



This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.

Tools Used

I. **Burp Suite**

II. **SQLMap**

III. **Nuclei**

IV. **Dirsearch**

This document is confidential to ASD-NIC. It must not be reproduced or circulated without prior approval from ASD-NIC.